

ZAP is highly extensible. It has a marketplace where additional add-ons can be downloaded (<https://www.zaproxy.org/addons/>).

Apart from this graphical user interface, ZAP has a very powerful API that enables you to do almost everything that can be done via the GUI. Detailed instructions on using the ZAP API are available at <https://www.zaproxy.org/docs/api/#introduction>.

sqlmap

sqlmap is a penetration testing tool. It is used for automating the detection of SQL injection. sqlmap supports plenty of databases such as MySQL, Oracle, Microsoft SQL server, etc (the full list is at <http://sqlmap.org/>). sqlmap can handle the following six types of SQL injection techniques:

- Boolean-based blind
- Error-based blind
- UNION query-based
- Time-based blind
- Stacked queries
- Out-of-band

sqlmap can be downloaded from <https://github.com/sqlmapproject/sqlmap/tarball/master>.

Wapiti

Wapiti (<https://wapiti.sourceforge.io/>) is an open source tool to audit the security of Web applications and websites. Wapiti carries out black-box scans of Web applications. It crawls the Web pages and then injects payloads to check for vulnerabilities. The current stable version of Wapiti is 3.0.3, which was released on February 20, 2020. Wapiti has the potential to scan many vulnerabilities, a few of which are listed below:

- Database injection
- Cross-site scripting
- File disclosure
- Server side request forgery (SSRF)
- Bypassing weak .htaccess configurations

Wapiti is a command line application. It can be downloaded from <https://sourceforge.net/projects/wapiti/files/>.

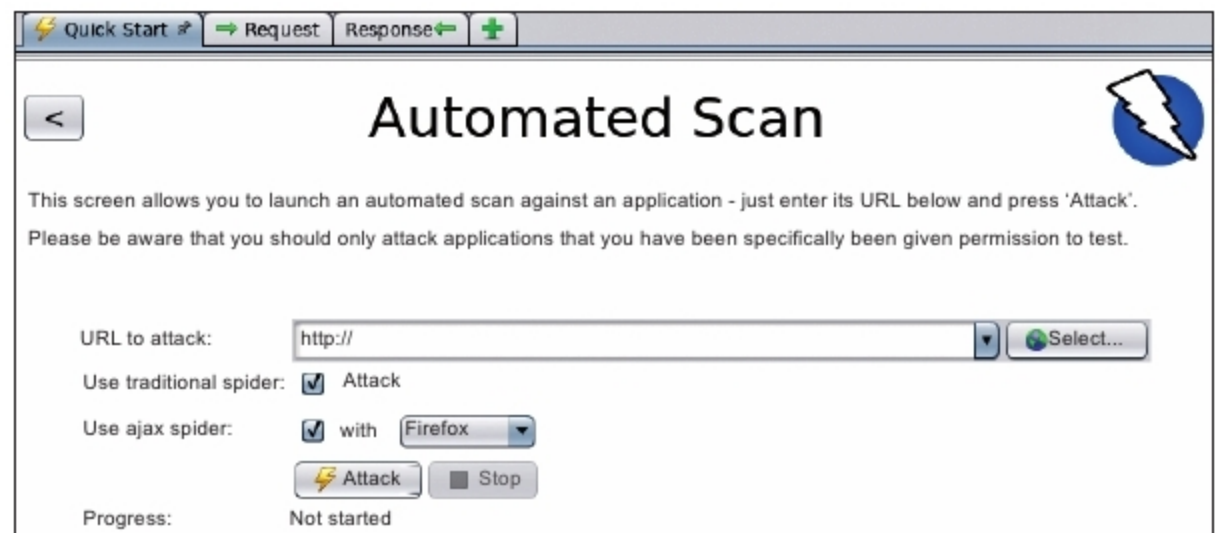


Figure 3: The ZAP automated scan

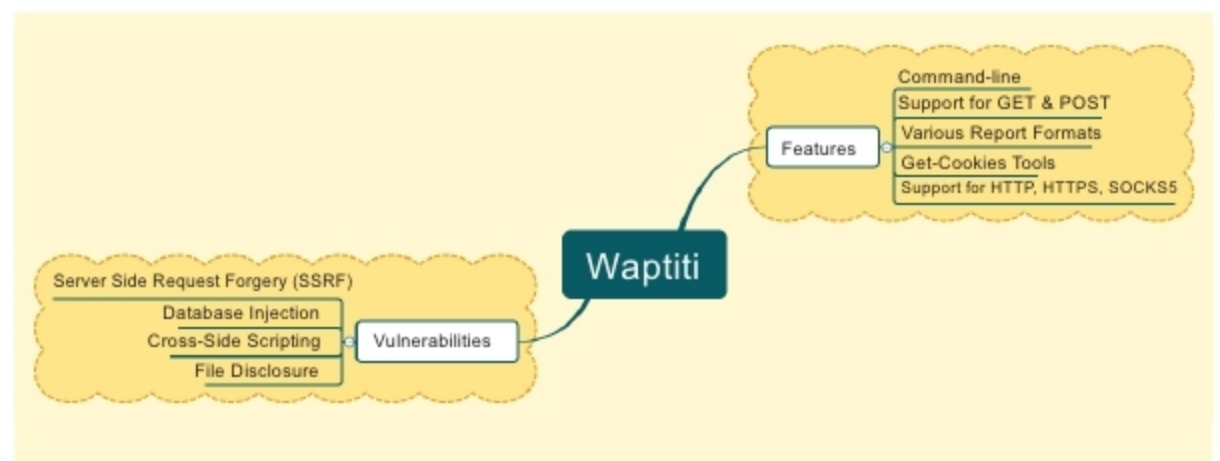


Figure 4: Wapiti's features

Wapiti has support for both GET and POST methods of HTTP for attacks. It can generate vulnerability reports in various formats such as HTML, JSON, XML, Plaintext, etc. It can be configured to work with different levels of verbosity. Adding payload in Wapiti is very simple.

Wapiti has another interesting feature called getcookie (the wapiti-getcookie tool). This can be used to import cookies. Wapiti can extract URLs from JavaScript and handle HTML 5 tags as well.

Wapiti has support for HTTP, HTTPS and SOCKS5 proxies. It has various options to control the behaviour of crawlers. It also has features to set the maximum time for scanning.

The simplest way to invoke Wapiti to perform a scan is shown below:

```
wapiti -u http://target/
```

This article gives a brief on five open source tools associated with the security of Web applications. There are many more tools available for similar tasks but covering all of them would not be viable here. If you are new to the Web application security domain, you can start with any of these tools, and explore further to acquire better insights into how to make Web applications more secure. **END** 🐧

References

- [1] <http://sqlmap.org/>
- [2] <https://www.zaproxy.org/>
- [3] <https://wapiti.sourceforge.io/>
- [4] <http://rgaucher.info/beta/grabber/>
- [5] <http://w3af.org/>

By: Dr K.S. Kuppusamy

The author is assistant professor of computer science, School of Engineering and Technology, Pondicherry Central University. He has 14+ years of teaching and research experience in academia and the industry. His research interests include accessible computing, Web information retrieval, mobile computing, etc.